

Индивидуальный проект. Этап 2

Артём Дмитриевич Петлин

Содержание

1	Цель работы	5
2	Задание	6
3	Теоретическое введение	7
4	Выполнение лабораторной работы	9
5	Выводы	12
	Список литературы	13

Список иллюстраций

4.1	git clone	9
4.2	cd DVWA	9
4.3	service mariadb start	10
4.4	mysql	10
4.5	service apache2 start	10
4.6	127.0.0.1/DVWA	11

Список таблиц

1 Цель работы

Научиться устанавливать DVWA в гостевую систему к Kali Linux.

2 Задание

Установите DVWA в гостевую систему к Kali Linux.

3 Теоретическое введение

- Некоторые из уязвимостей веб приложений, который содержит DVWA:

Брутфорс: Брутфорс HTTP формы страницы входа - используется для тестирования инструментов по атаке на пароль методом грубой силы и показывает небезопасность слабых паролей.

Исполнение (внедрение) команд: Выполнение команд уровня операционной системы.

Межсайтовая подделка запроса (CSRF): Позволяет «атакующему» изменить пароль администратора приложений.

Внедрение (инклюд) файлов: Позволяет «атакующему» присоединить удалённые/локальные файлы в веб приложение.

SQL внедрение: Позволяет «атакующему» внедрить SQL выражения в HTTP из поля ввода, DVWA включает слепое и основанное на ошибке SQL внедрение.

Небезопасная выгрузка файлов: Позволяет «атакующему» выгрузить вредоносные файлы на веб сервер.

Межсайтовый скриптинг (XSS): «Атакующий» может внедрить свои скрипты в веб приложение/базу данных. DVWA включает отражённую и хранимую XSS.

Пасхальные яйца: раскрытие полных путей, обход аутентификации и некоторые другие.

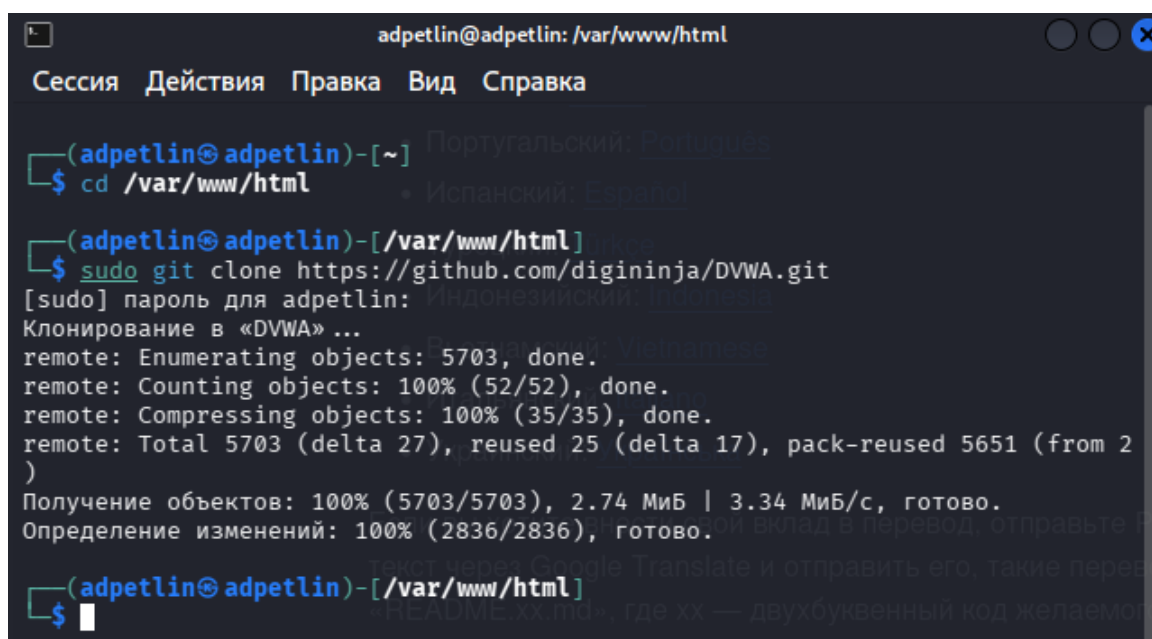
- DVWA имеет три уровня безопасности, они меняют уровень безопасности каждого веб приложения в DVWA:

Невозможный — этот уровень должен быть безопасным от всех уязвимостей. Он используется для сравнения уязвимого исходного кода с безопасным исходным кодом.

Высокий — это расширение среднего уровня сложности, со смесью более сложных или альтернативных плохих практик в попытке обезопасить код. Уязвимости не позволяют такой простор эксплуатации как на других уровнях. Средний — этот уровень безопасности предназначен главным образом для того, чтобы дать пользователю пример плохих практик безопасности, где разработчик попытался сделать приложение безопасным, но потерпел неудачу.

Низкий — этот уровень безопасности совершенно уязвим и совсем не имеет защиты. Его предназначение быть примером среди уязвимых веб-приложений, примером плохих практик программирования и служить платформой обучения базовым техникам эксплуатации.

4 Выполнение лабораторной работы

A terminal window titled 'adpetlin@adpetlin: /var/www/html' with a menu bar 'Сессия Действия Правка Вид Справка'. The prompt is '(adpetlin@adpetlin)-[~]'. The user enters 'cd /var/www/html'. The prompt changes to '(adpetlin@adpetlin)-[/var/www/html]'. The user enters 'sudo git clone https://github.com/digininja/DVWA.git'. The terminal shows the cloning progress: 'Клонирование в «DVWA» ...', 'remote: Enumerating objects: 5703, done.', 'remote: Counting objects: 100% (52/52), done.', 'remote: Compressing objects: 100% (35/35), done.', 'remote: Total 5703 (delta 27), reused 25 (delta 17), pack-reused 5651 (from 2)', 'Получение объектов: 100% (5703/5703), 2.74 МиБ | 3.34 МиБ/с, готово.', 'Определение изменений: 100% (2836/2836), готово.' The prompt returns to '(adpetlin@adpetlin)-[/var/www/html]'.

```
adpetlin@adpetlin: /var/www/html
Сессия Действия Правка Вид Справка

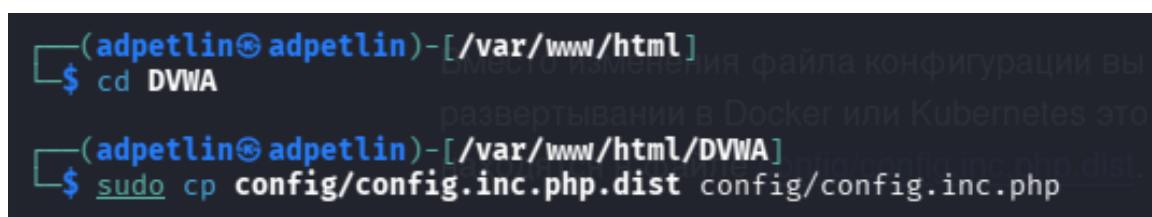
(adpetlin@adpetlin)-[~]
$ cd /var/www/html

(adpetlin@adpetlin)-[/var/www/html]
$ sudo git clone https://github.com/digininja/DVWA.git
[sudo] пароль для adpetlin:
Клонирование в «DVWA» ...
remote: Enumerating objects: 5703, done.
remote: Counting objects: 100% (52/52), done.
remote: Compressing objects: 100% (35/35), done.
remote: Total 5703 (delta 27), reused 25 (delta 17), pack-reused 5651 (from 2)
Получение объектов: 100% (5703/5703), 2.74 МиБ | 3.34 МиБ/с, готово.
Определение изменений: 100% (2836/2836), готово.

(adpetlin@adpetlin)-[/var/www/html]
$
```

Рисунок 4.1: git clone

Переходим в директорию веб-сервера и скачиваем исходный код DVWA с GitHub.

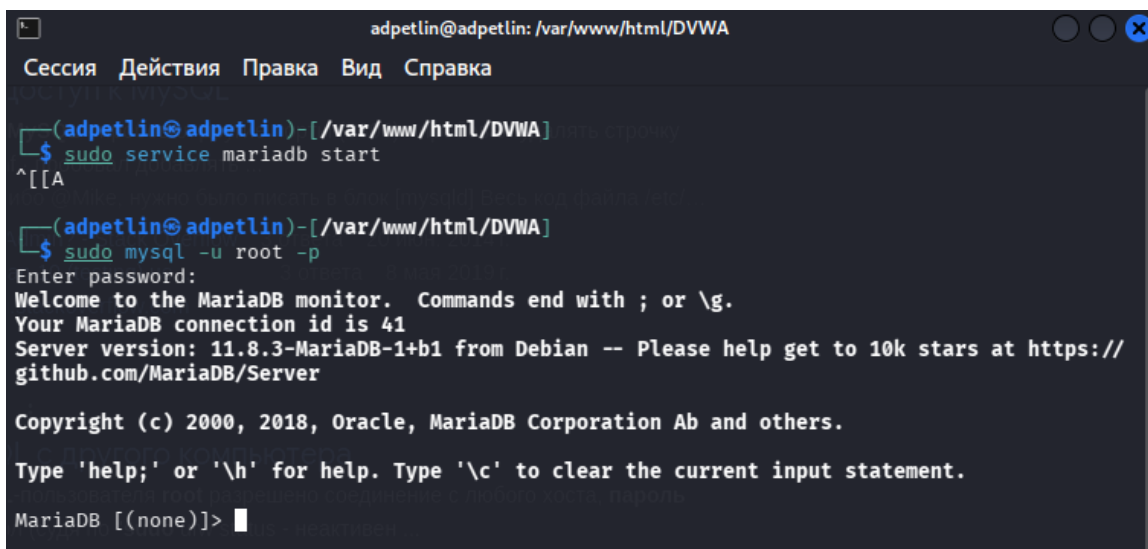
A terminal window showing the next steps. The prompt is '(adpetlin@adpetlin)-[/var/www/html]'. The user enters 'cd DVWA'. The prompt changes to '(adpetlin@adpetlin)-[/var/www/html/DVWA]'. The user enters 'sudo cp config/config.inc.php.dist config/config.inc.php'.

```
(adpetlin@adpetlin)-[/var/www/html]
$ cd DVWA

(adpetlin@adpetlin)-[/var/www/html/DVWA]
$ sudo cp config/config.inc.php.dist config/config.inc.php
```

Рисунок 4.2: cd DVWA

Заходим в папку с приложением и копируем шаблон конфигурации.



```
adpetlin@adpetlin: /var/www/html/DVWA
Сессия Действия Правка Вид Справка
(adpetlin@adpetlin)-[/var/www/html/DVWA]
$ sudo service mariadb start
^[[A
(adpetlin@adpetlin)-[/var/www/html/DVWA]
$ sudo mysql -u root -p
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 41
Server version: 11.8.3-MariaDB-1+b1 from Debian -- Please help get to 10k stars at https://github.com/MariaDB/Server

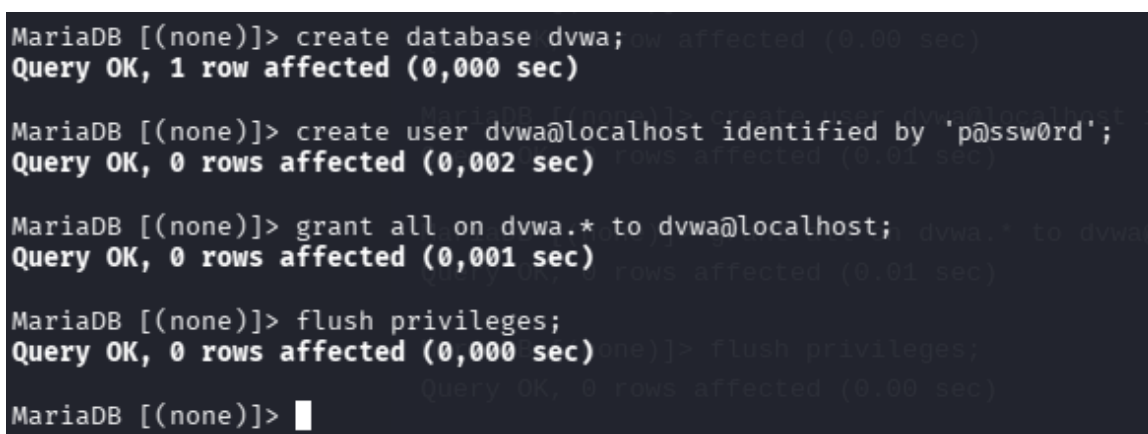
Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> 
```

Рисунок 4.3: service mariadb start

Запускаем службу MariaDB и входим в консоль управления ею.



```
MariaDB [(none)]> create database dvwa;
Query OK, 1 row affected (0.00 sec)

MariaDB [(none)]> create user dvwa@localhost identified by 'p@ssw0rd';
Query OK, 0 rows affected (0.002 sec)

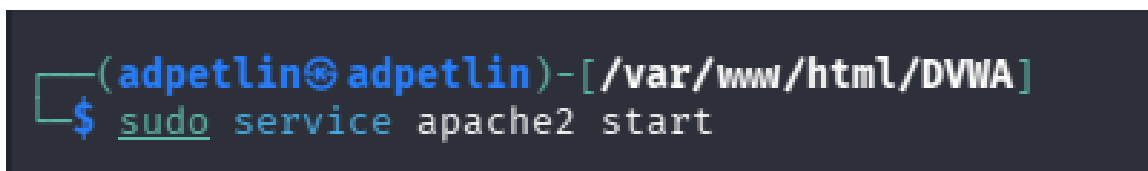
MariaDB [(none)]> grant all on dvwa.* to dvwa@localhost;
Query OK, 0 rows affected (0.001 sec)

MariaDB [(none)]> flush privileges;
Query OK, 0 rows affected (0.000 sec)

MariaDB [(none)]> 
```

Рисунок 4.4: mysql

Находясь внутри консоли MariaDB, создаем базу данных, пользователя и выдаем ему права.



```
(adpetlin@adpetlin)-[/var/www/html/DVWA]
$ sudo service apache2 start
```

Рисунок 4.5: service apache2 start

Запускаем веб-сервер Apache.

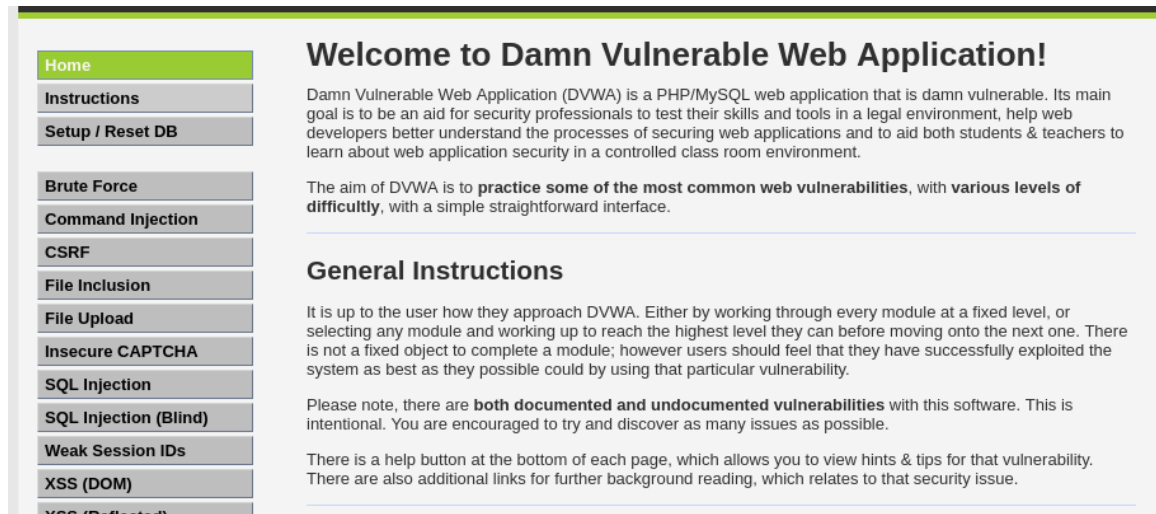


Рисунок 4.6: 127.0.0.1/DVWA

В браузере открываем localhost (127.0.0.1/DVWA) и авторизуемся по умолчанию после нажимаем «create database», снова авторизуемся и база данных создана и с ней можно работать.

5 Выводы

Мы научились устанавливать DVWA в гостевую систему к Kali Linux.

Список литературы